

Lesson 01 Demo 03

Running SAST Scan on a Static Web Application Using GitHub

Objective: To run a SAST scan on a static web application using GitHub workflows integrated with Semgrep for secure code analysis and validation

Tools required: GitHub Actions and Semgrep SAST tool

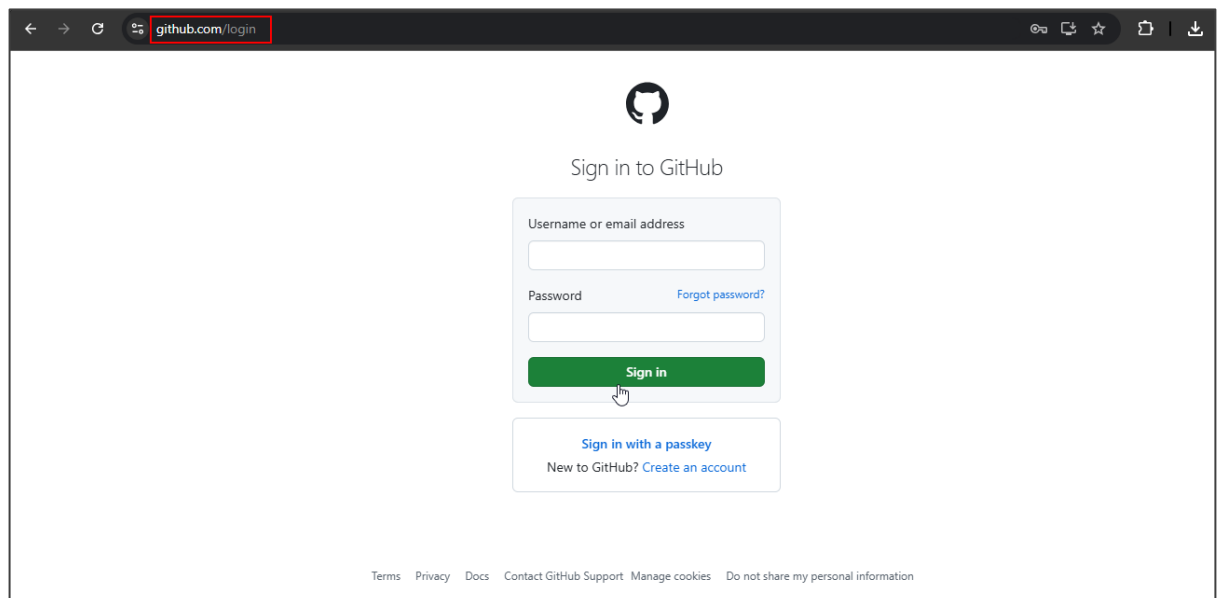
Prerequisites: None

Steps to be followed:

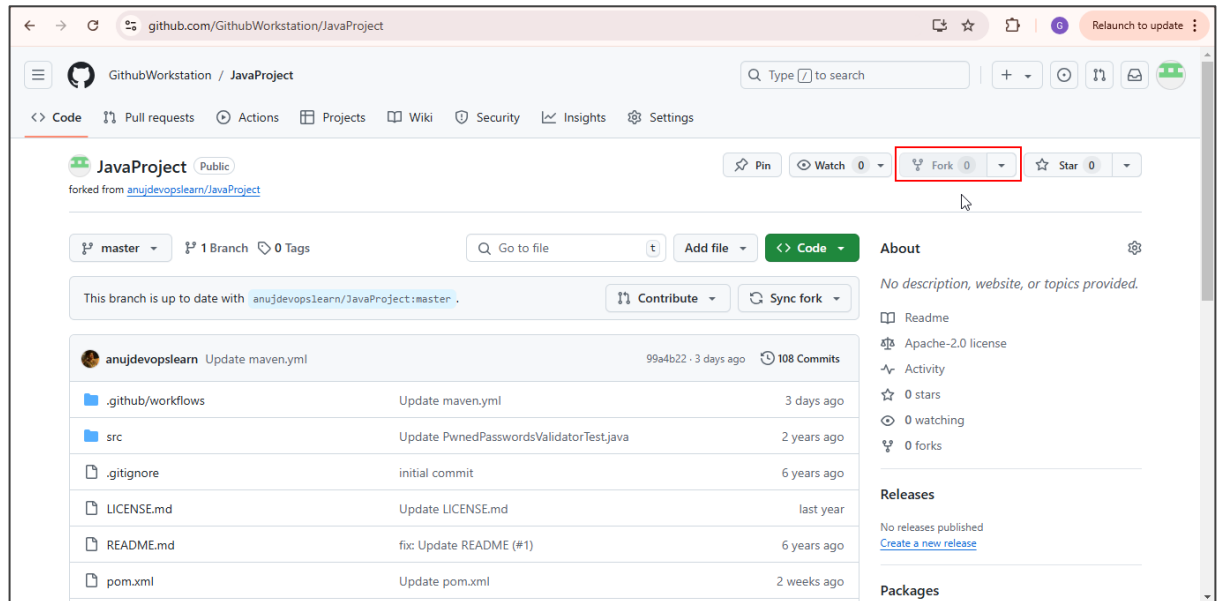
1. Fork the GitHub repository
2. Set up a workflow
3. Connect the GitHub account with Semgrep
4. Validate the SAST scan

Step 1: Fork the GitHub repository

- 1.1 Sign in to your GitHub account using the following URL:
<https://github.com/login>

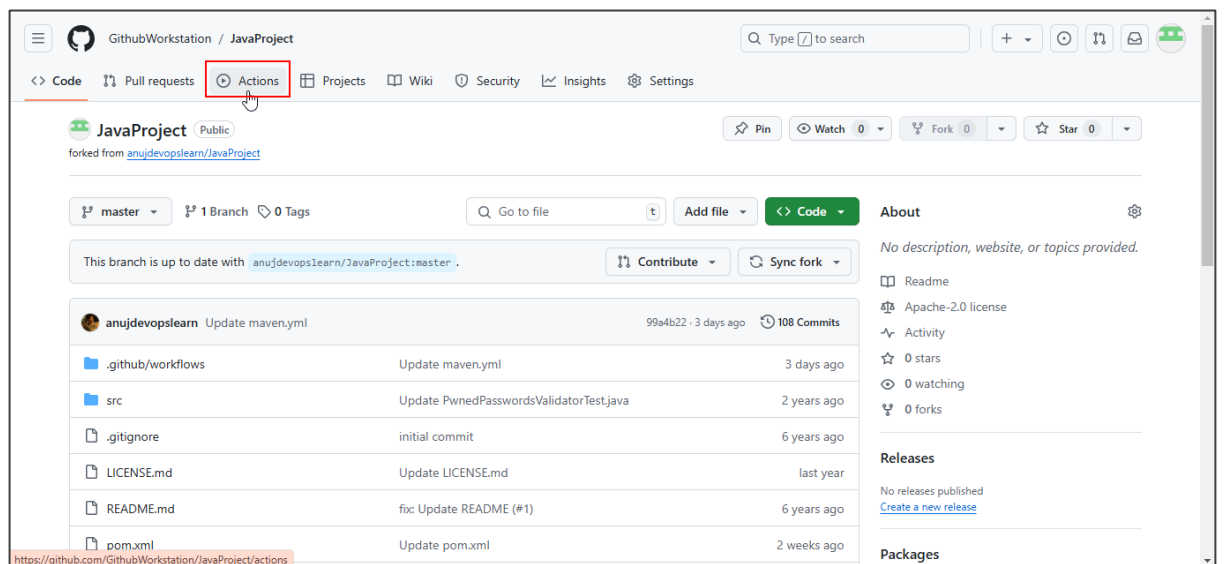


1.2 Fork the following repository: <https://github.com/GithubWorkstation/JavaProject>

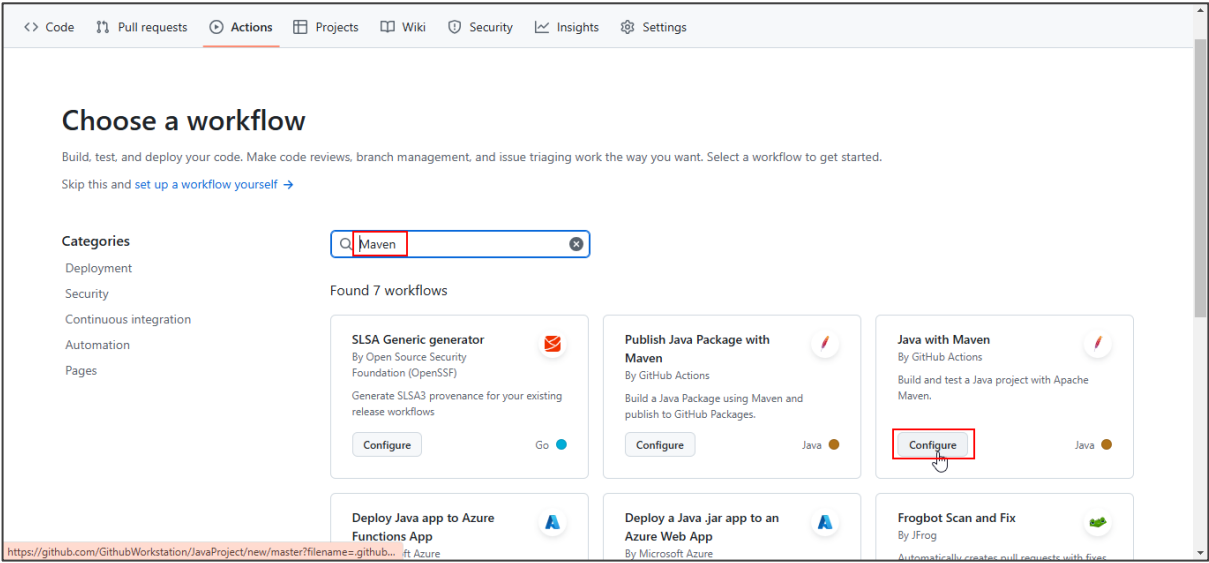


Step 2: Set up a workflow

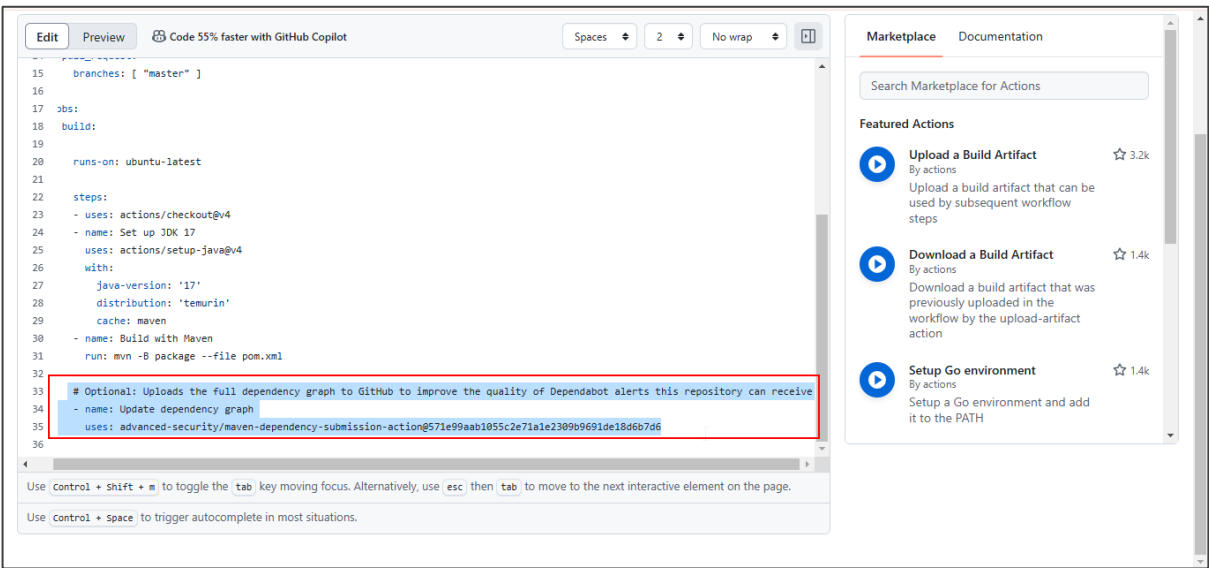
2.1 Click on the Actions tab



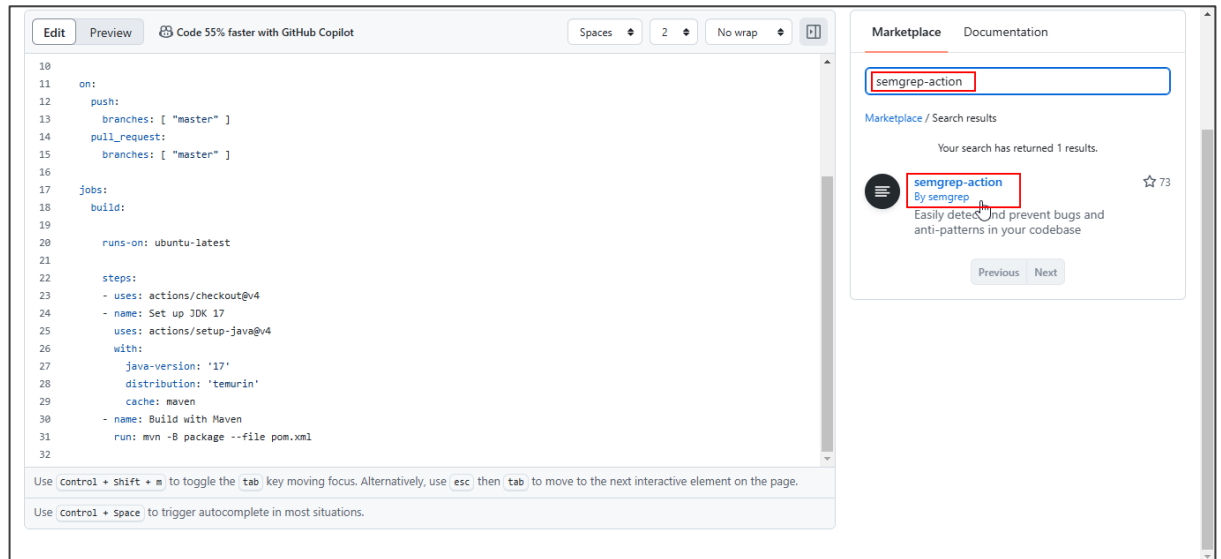
2.2 Search for **Maven** and click on **Configure** in the **Java with Maven** workflow as shown below:



2.3 Remove the optional step from the workflow as shown below:



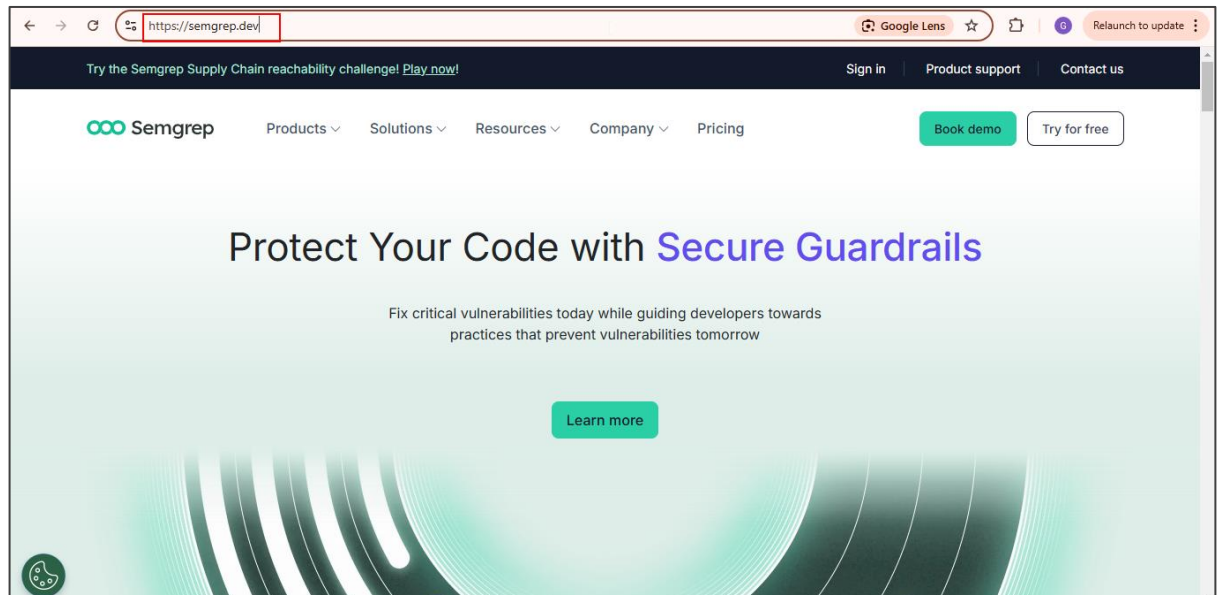
2.4 Search for and select **semgrep-action** from **Marketplace** to proceed with integration in the workflow



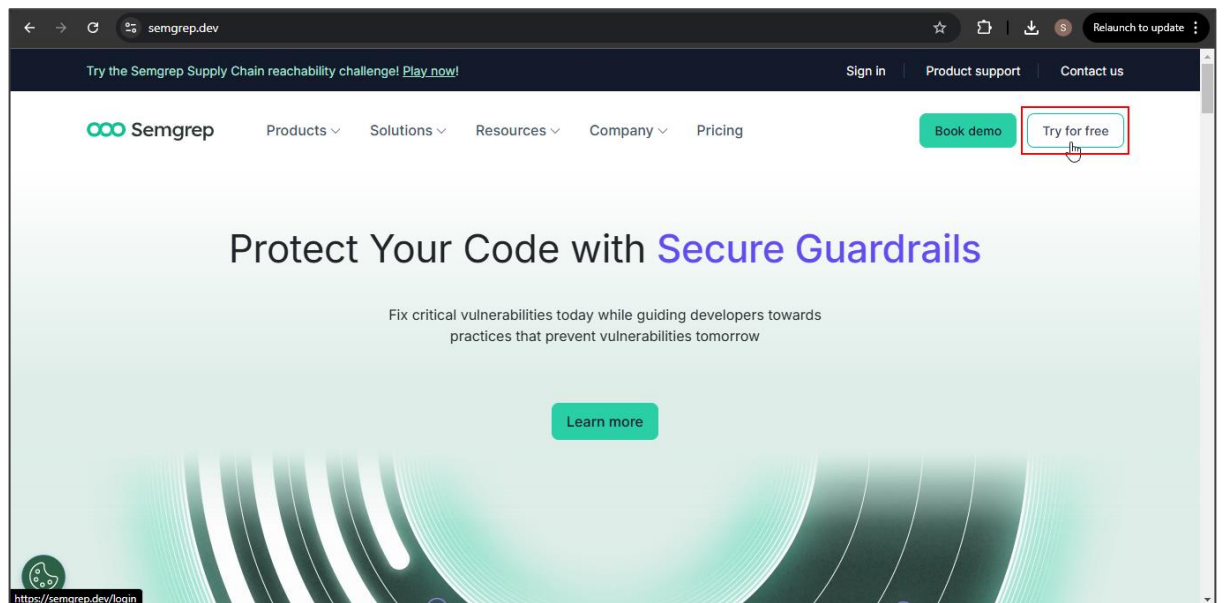
Note: The access token will be generated in the subsequent steps.

Step 3: Connect the GitHub account with Semgrep

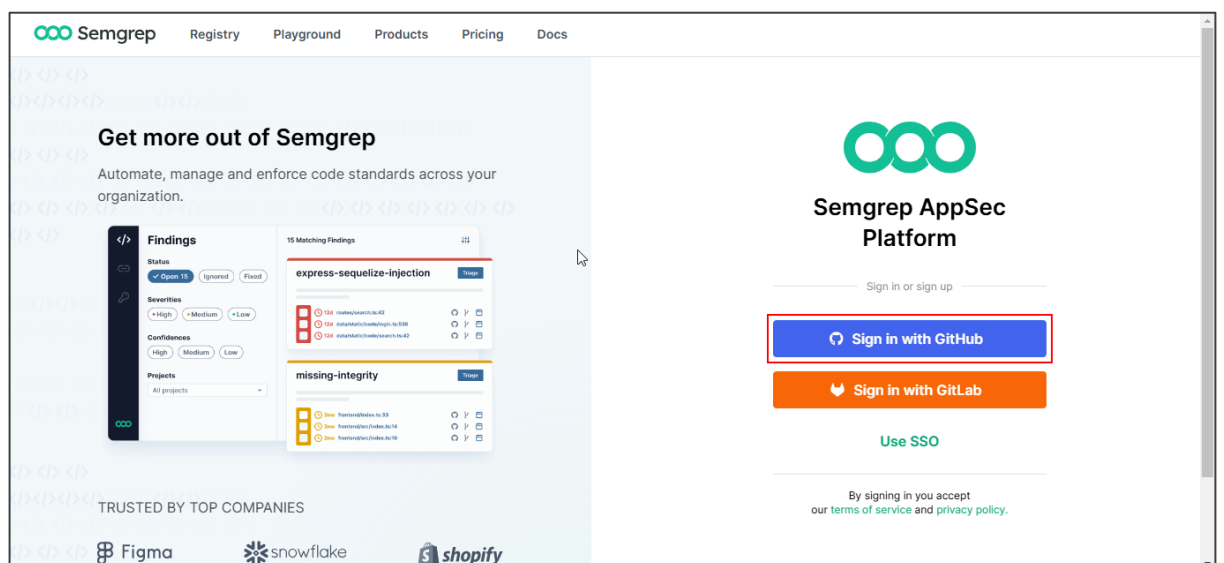
3.1 Navigate to Semgrep website using the following link: <https://semgrep.dev/>



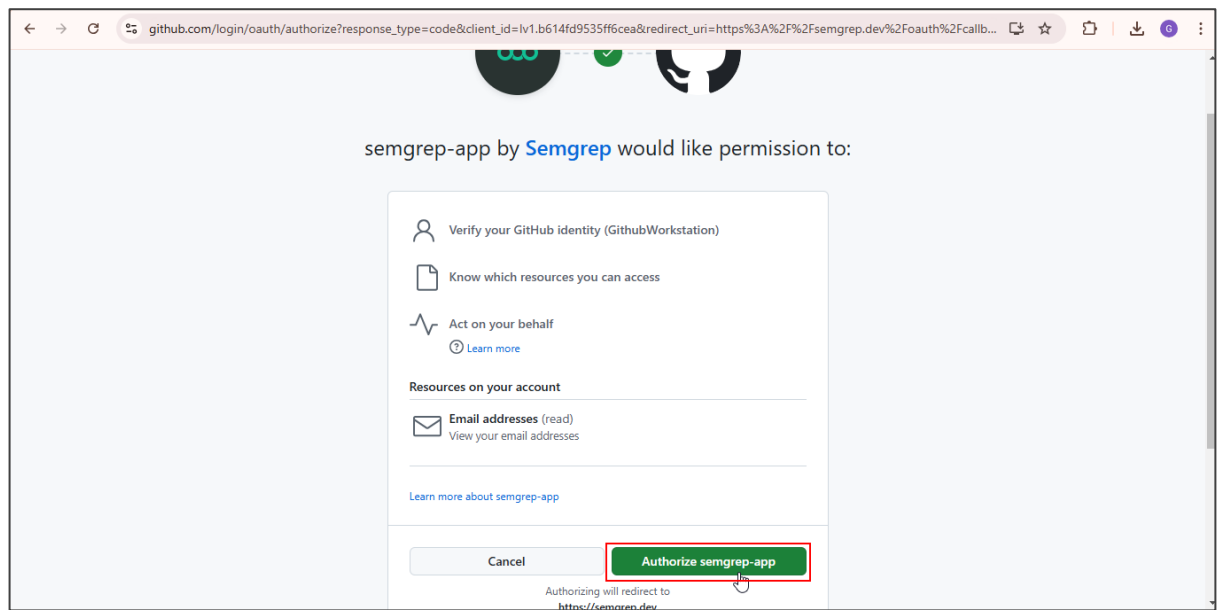
3.2 Click on **Try for free**



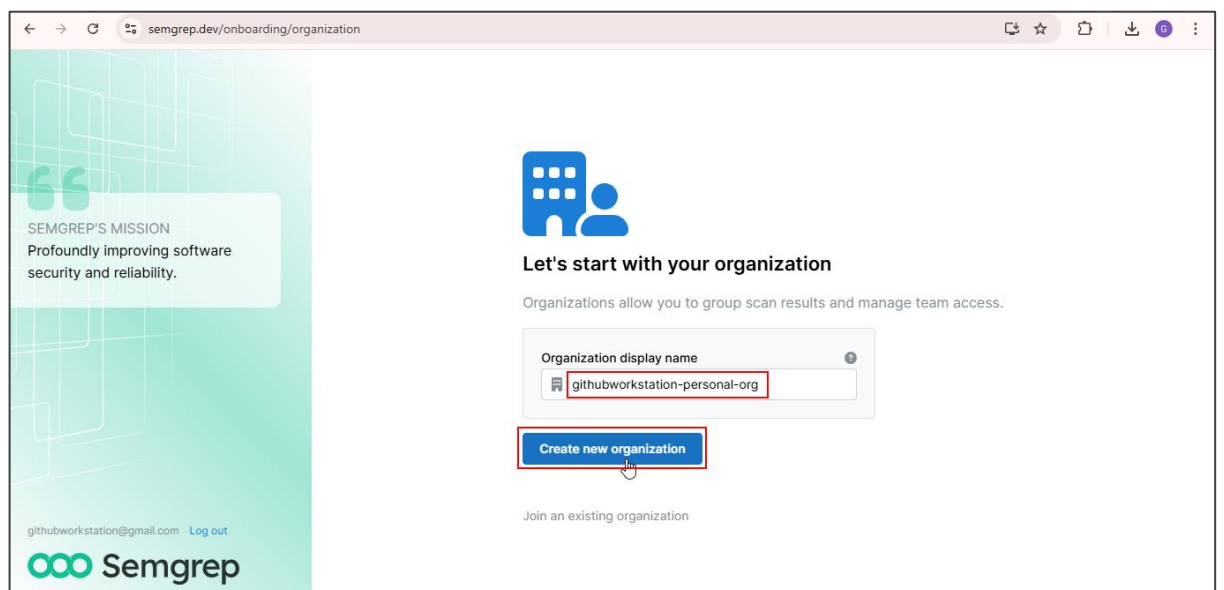
3.3 Click on the **Sign in with GitHub** button



3.4 Click **Authorize semgrep-app**



3.5 Add the organization's name and click **Create new organization**



3.6 Select the required option and click **Continue**

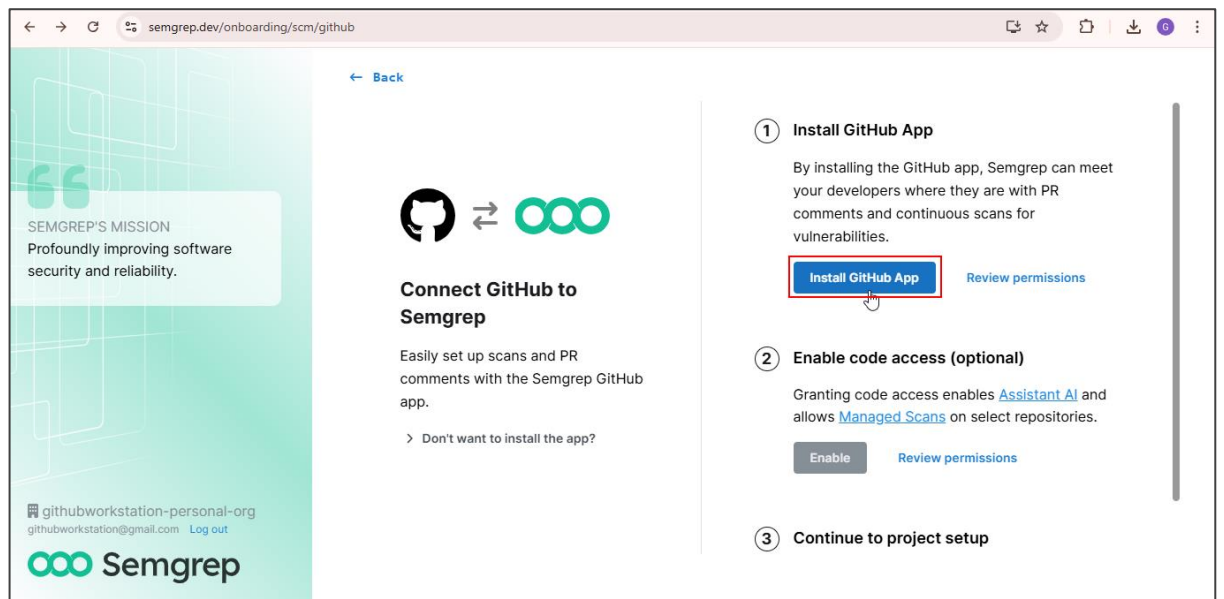
The screenshot shows the Semgrep onboarding survey page at `semgrep.dev/onboarding/survey`. On the left, a sidebar contains the Semgrep logo, the text "SEMGREP'S MISSION: Profoundly improving software security and reliability.", and user information for "githubworkstation-personal-org" with a "Log out" link. The main content area is titled "How are you planning to use Semgrep?" and features three radio button options: "For work", "For academic purposes", and "For a personal project". The "For a personal project" option is selected and highlighted with a red box. Below the options is a blue "Continue" button, also highlighted with a red box. In the background, a dashboard preview is visible, showing sections for "Code Audit Rules", "New advisories", and a "Most findings" table.

Project Name	Open Findings	High Severity	Fix Rate
hack01000/typical-shop	144	46	81%
hack01000/magical	58	19	25%
hack01000/spectroscopy	93	6	75%

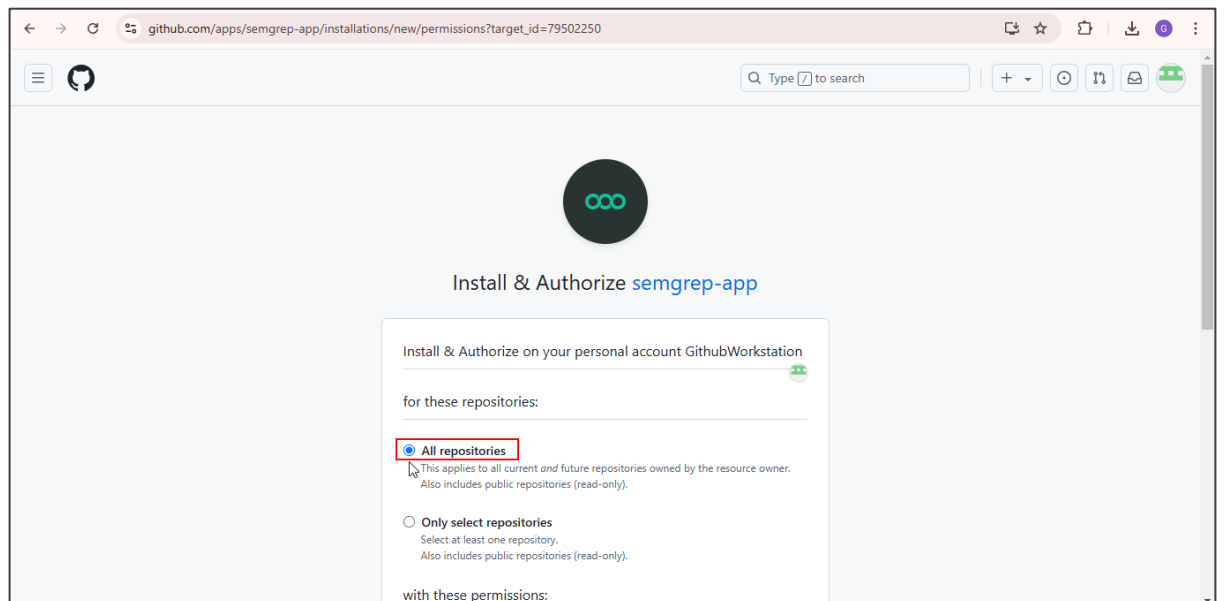
3.7 Select **GitHub** to scan the code

The screenshot shows the Semgrep onboarding page at `semgrep.dev/onboarding/scm`. The sidebar on the left is identical to the previous page. The main content area is titled "Where do you want to scan?" and includes the text "Connecting a service allows Semgrep to scan your code." Below this, there are four buttons: "GitHub", "GitLab", "Run on CLI", and "Other Providers". The "GitHub" button is highlighted with a red box and a mouse cursor. At the bottom, there is a link that says "Don't want to connect anything yet?".

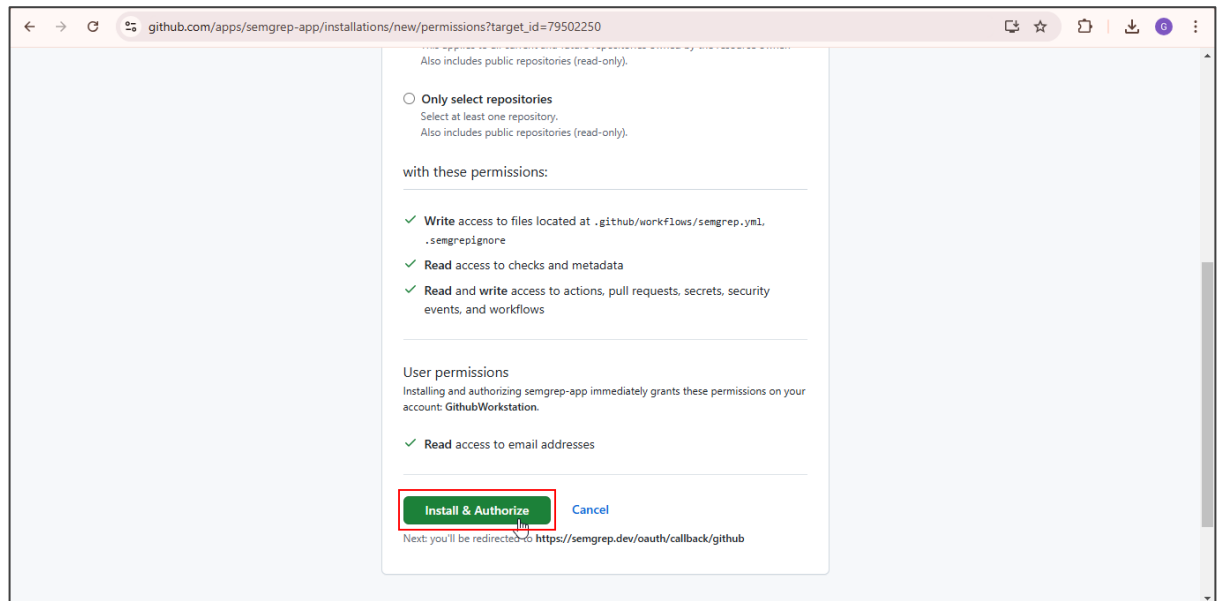
3.8 Click on **Install GitHub App**



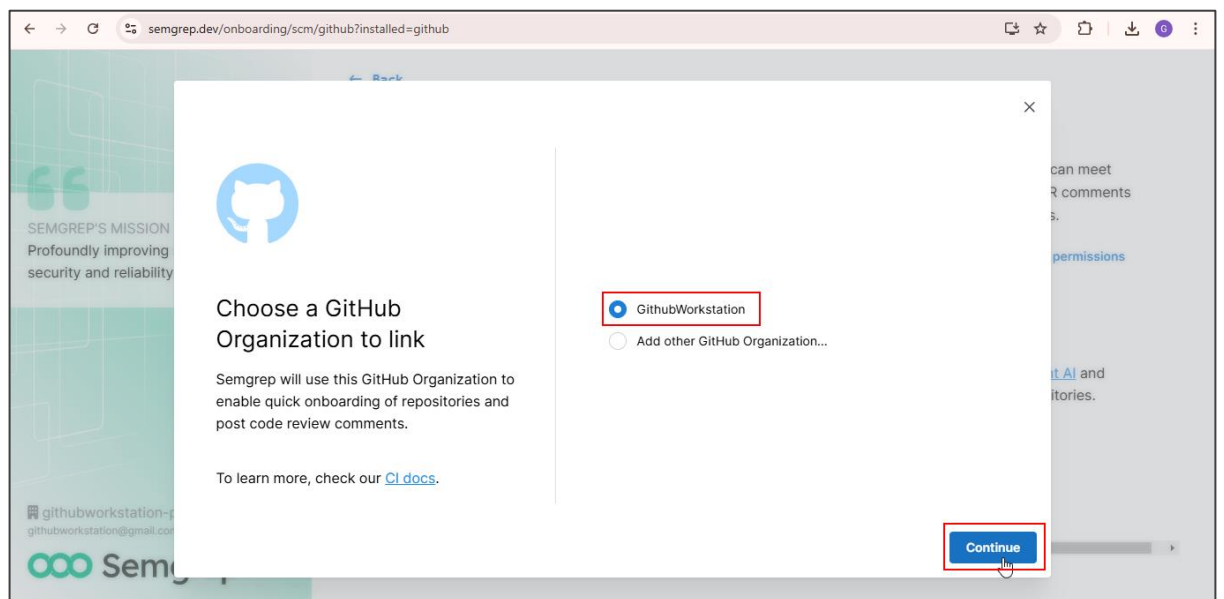
3.9 Select **All repositories**



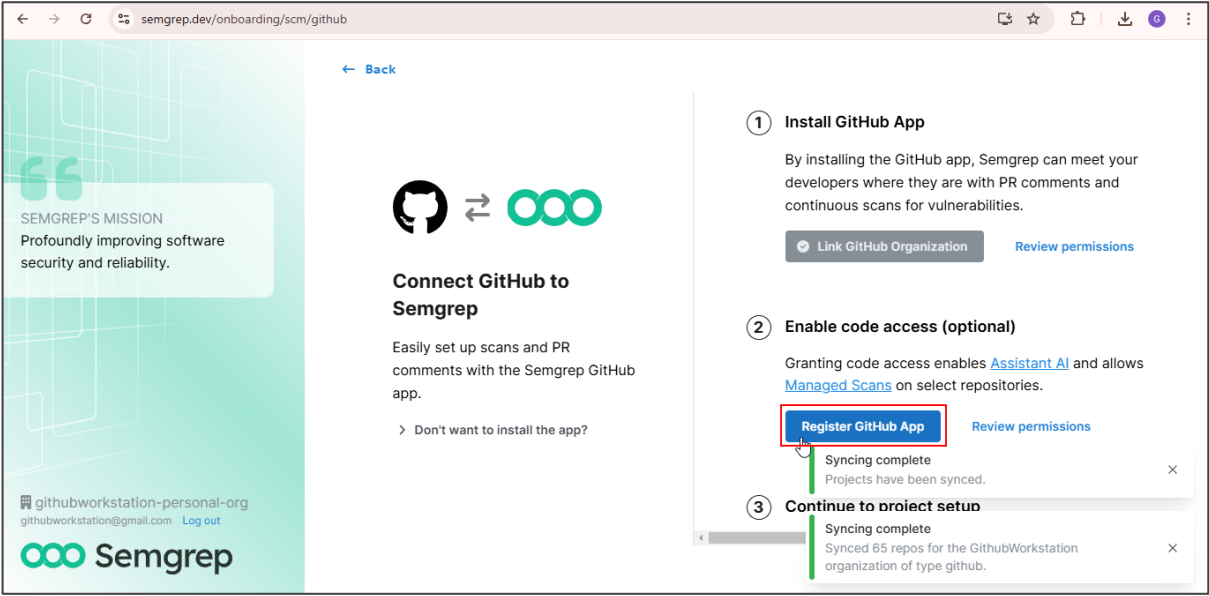
3.10 Click **Install and Authorize**



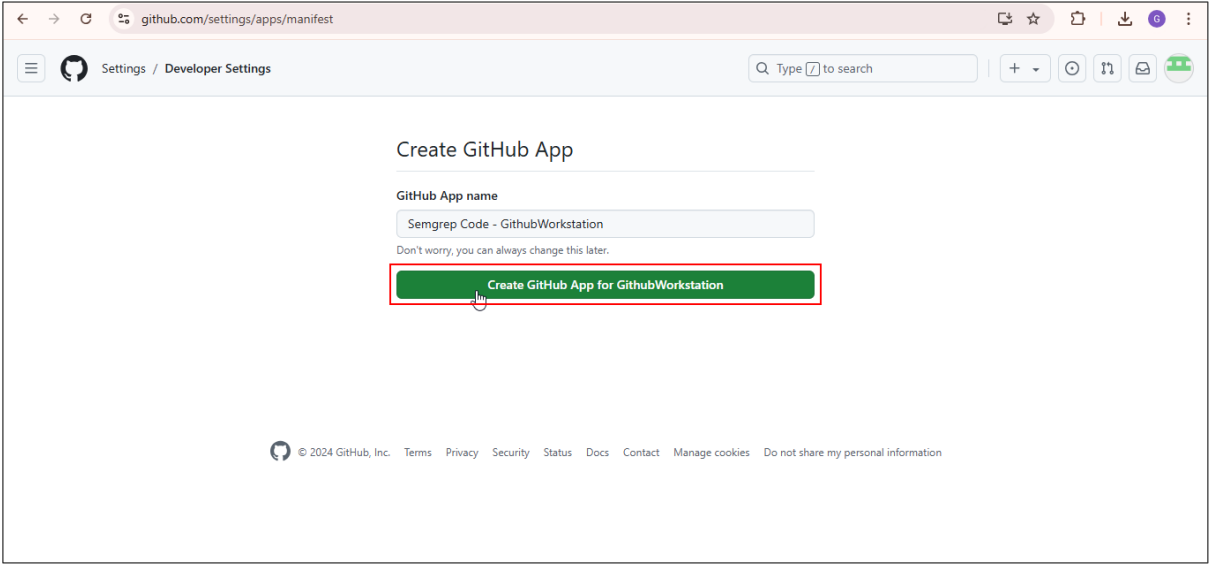
3.11 Select the account and click **Continue**



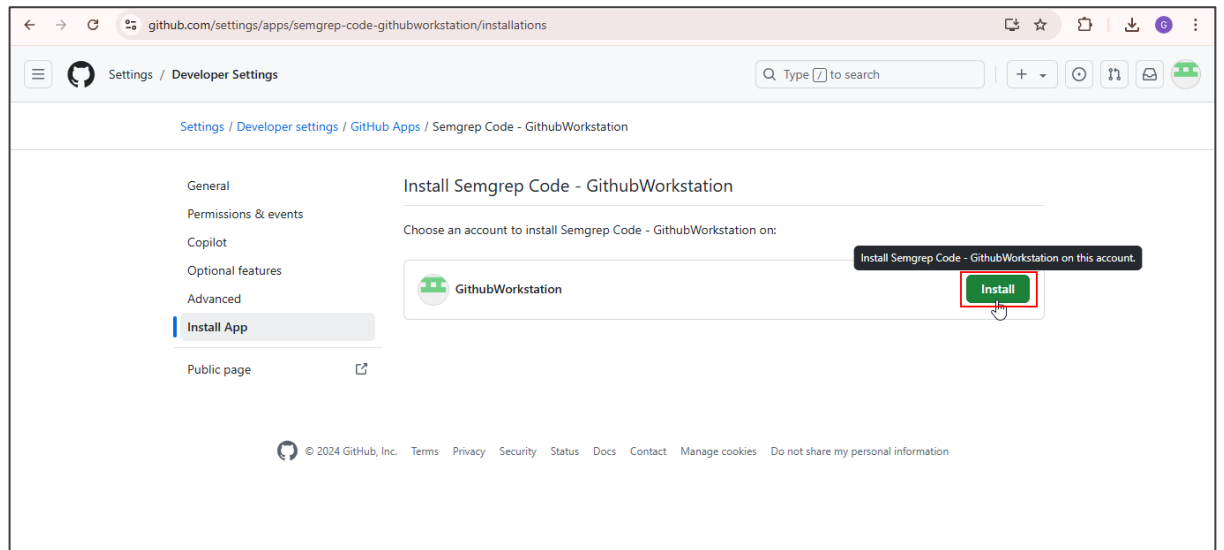
3.12 Click **Register GitHub App**



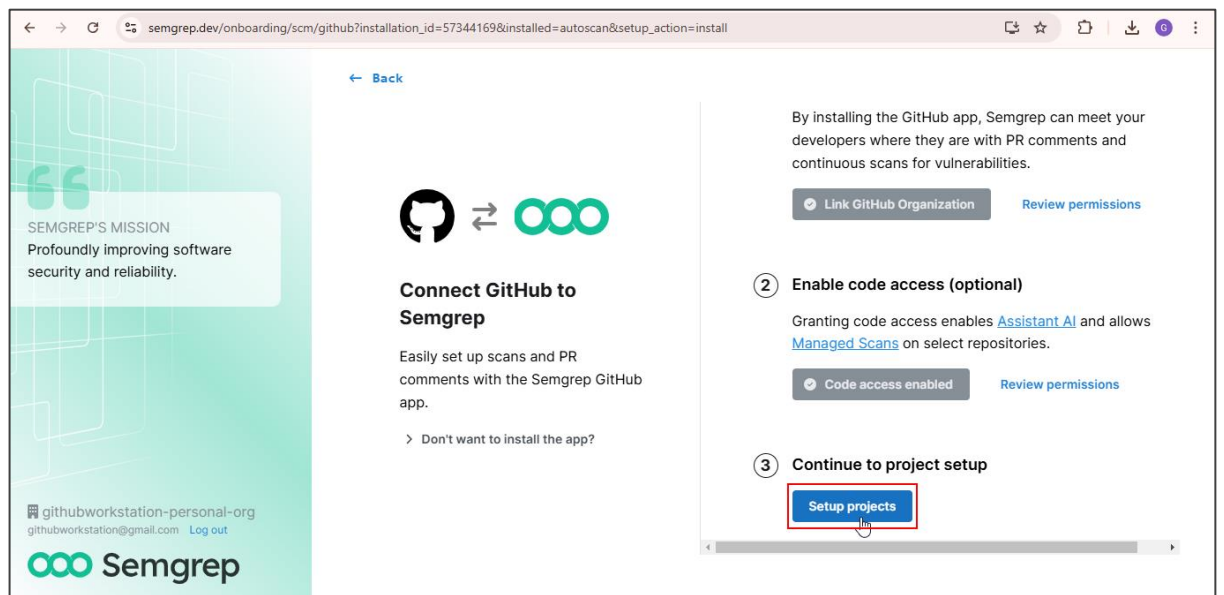
3.13 Click **Create GitHub App for GithubWorkstation** as shown below:



3.14 Click on **Install**

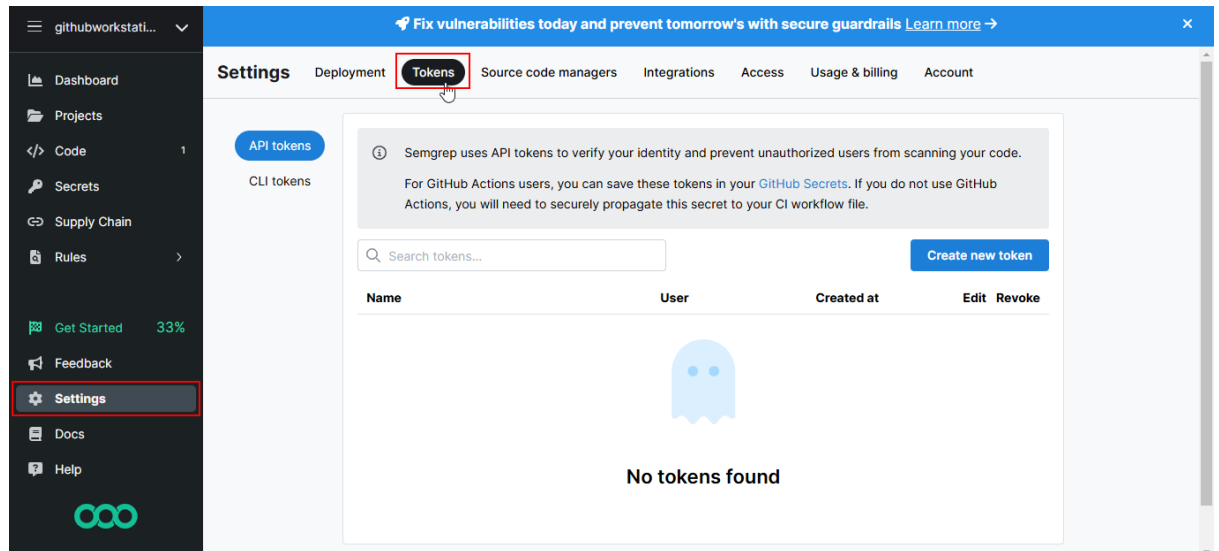


3.15 Click on **Setup projects**

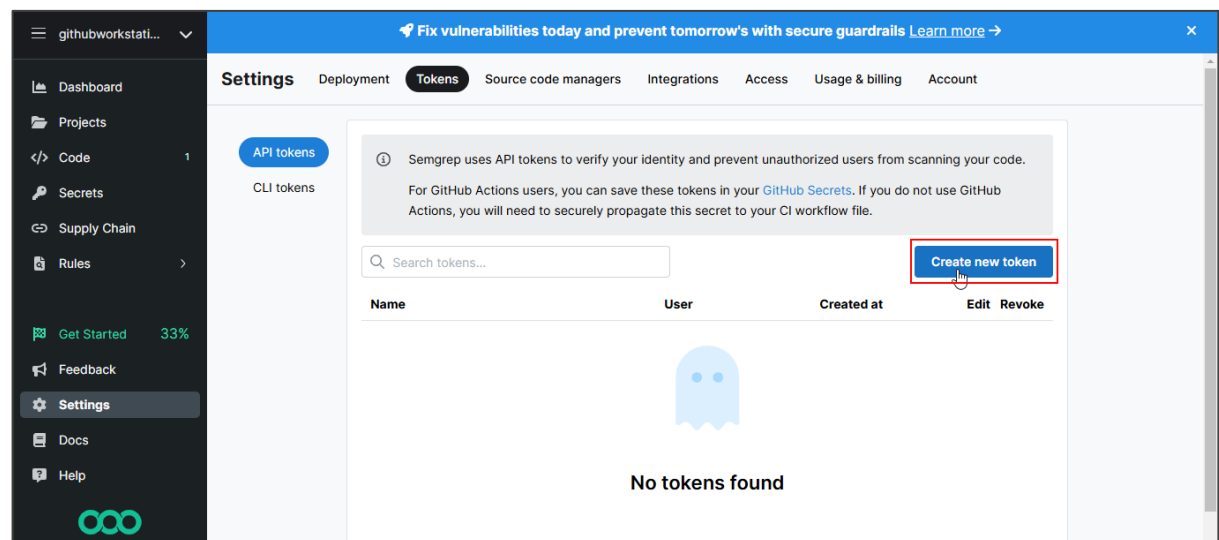


Step 4: Validate the SAST scan

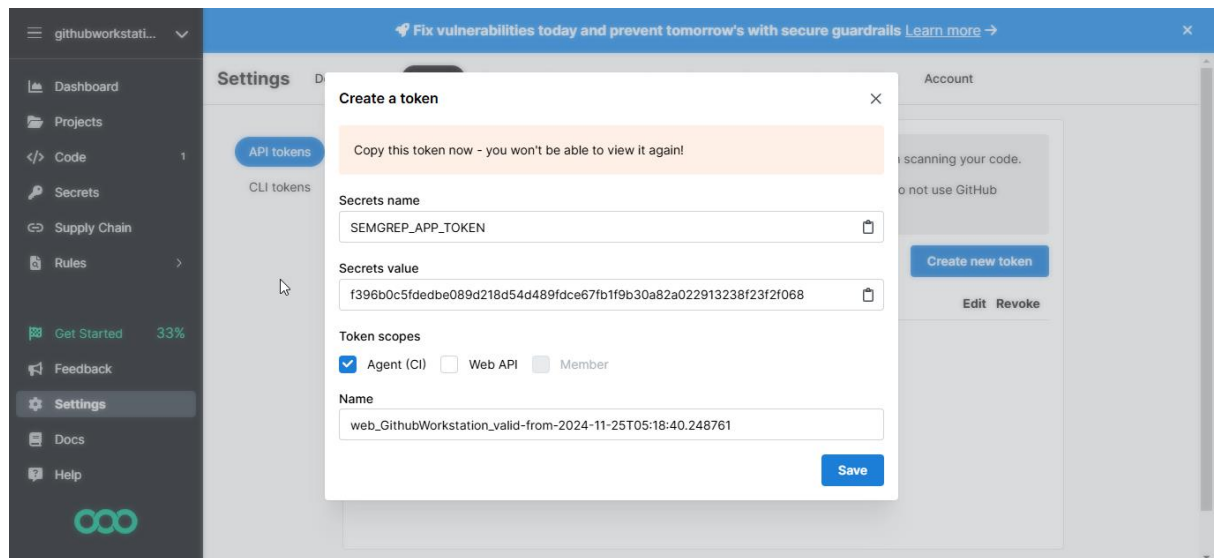
4.1 Click **Settings** and then click on **Tokens** as shown below:



4.2 Click on **Create new token**



You will see the following interface:



Note: Copy the **Secrets value**

- 4.4 Copy the following Semgrep configuration and paste it into the **maven.yml** file, and then click on **Commit changes...**

```
# This workflow will build a Java project with Maven, and cache/restore any
dependencies to improve the workflow execution time
# For more information see: https://docs.github.com/en/actions/automating-
builds-and-tests/building-and-testing-java-with-maven
```

```
# This workflow uses actions that are not certified by GitHub.
# They are provided by a third-party and are governed by
# separate terms of service, privacy policy, and support
# documentation.
```

```
name: Java CI with Maven
```

```
on:
```

```
  push:
```

```
    branches: [ "master" ]
```

```
  pull_request:
```

```
    branches: [ "master" ]
```

```
jobs:
```

```
  build:
```

```
    runs-on: ubuntu-latest
```

```
    steps:
```

```
      - uses: actions/checkout@v4
```

```
      - name: Set up JDK 17
```

```
        uses: actions/setup-java@v4
```

with:

java-version: '17'

distribution: 'temurin'

cache: maven

- name: Build with Maven

run: mvn -B package --file pom.xml

semgrep:

User definable name of this GitHub Actions job.

name: semgrep/ci

If you are self-hosting, change the following `runs-on` value:

runs-on: ubuntu-latest

container:

A Docker image with Semgrep installed. Do not change this.

image: semgrep/semgrep

steps:

Fetch project source with GitHub Actions Checkout. Use either v3 or v4.

- uses: actions/checkout@v4

Run the "semgrep ci" command on the command line of the docker image.

- run: semgrep ci --sarif > semgrep.sarif

env:

Connect to Semgrep AppSec Platform through your

SEMGREP_APP_TOKEN.

Generate a token from Semgrep AppSec Platform > Settings

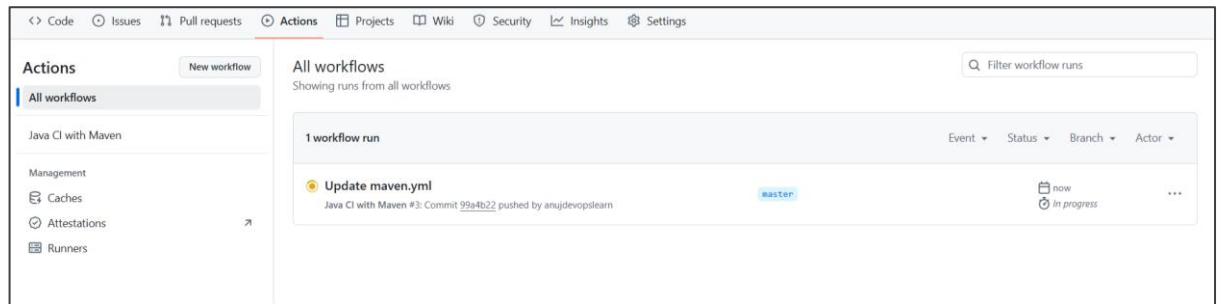
and add it to your GitHub secrets.

SEMGREP_APP_TOKEN: "YOUR_TOKEN"

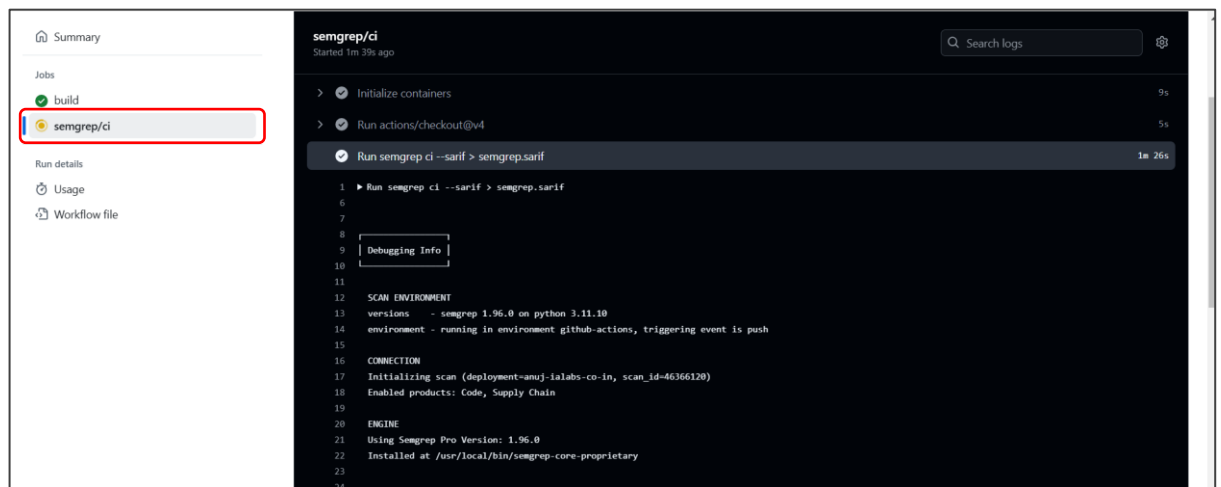
```
30 - name: Build with Maven
31 run: mvn -B package --file pom.xml
32
33 semgrep:
34   # User definable name of this GitHub Actions job.
35   name: semgrep/ci
36   # If you are self-hosting, change the following `runs-on` value:
37   runs-on: ubuntu-latest
38   container:
39     # A Docker image with Semgrep installed. Do not change this.
40     image: semgrep/semgrep
41   steps:
42     # Fetch project source with GitHub Actions Checkout. Use either v3 or v4.
43     - uses: actions/checkout@v4
44     # Run the "semgrep ci" command on the command line of the docker image.
45     - run: semgrep ci --sarif > semgrep.sarif
46   env:
47     # Connect to Semgrep AppSec Platform through your SEMGREP_APP_TOKEN.
48     # Generate a token from Semgrep AppSec Platform > Settings
49     # and add it to your GitHub secrets.
50     SEMGREP_APP_TOKEN: "f396b0c5fde8be889d218d54d489fdce67fb1f9b30a82a022913238f23f2f068"
51
```

Note: Replace **YOUR_TOKEN** with the token copied in the previous step

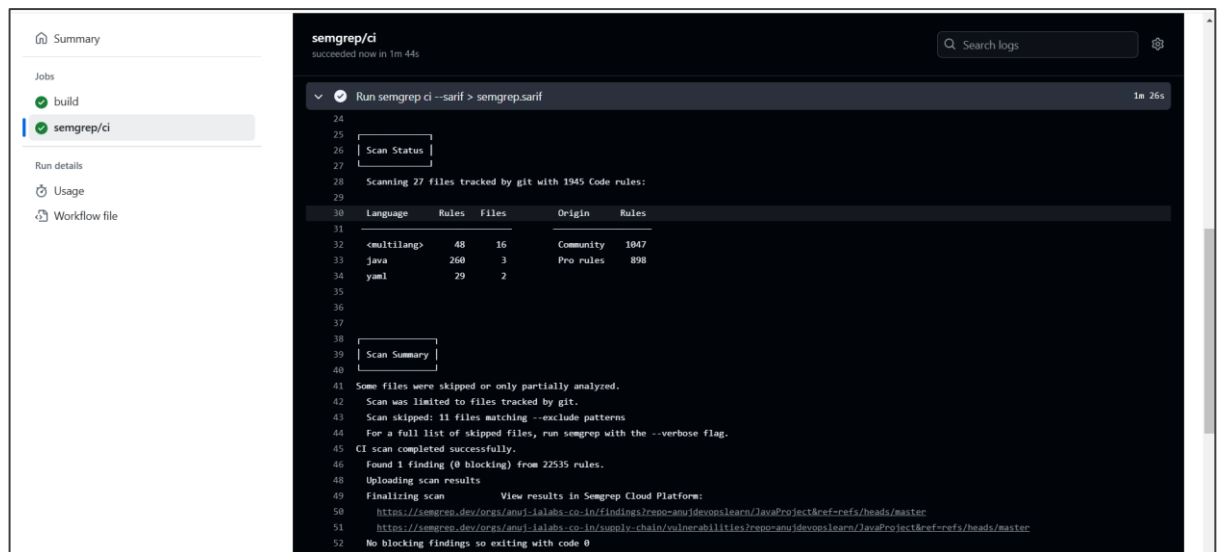
You will see that the pipeline has been invoked successfully.



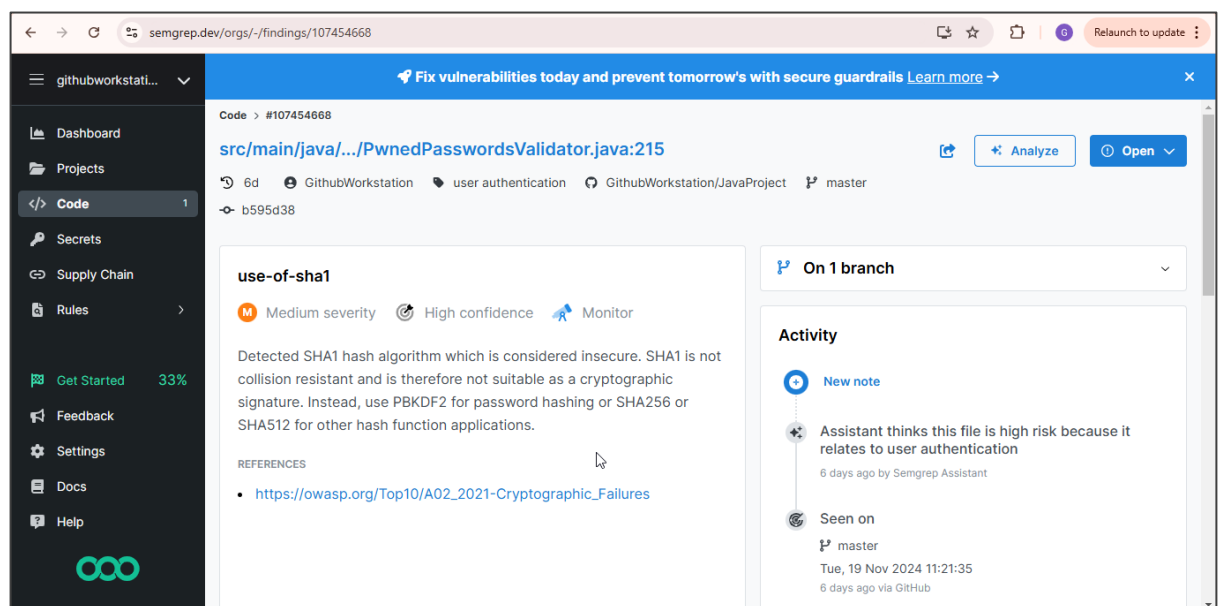
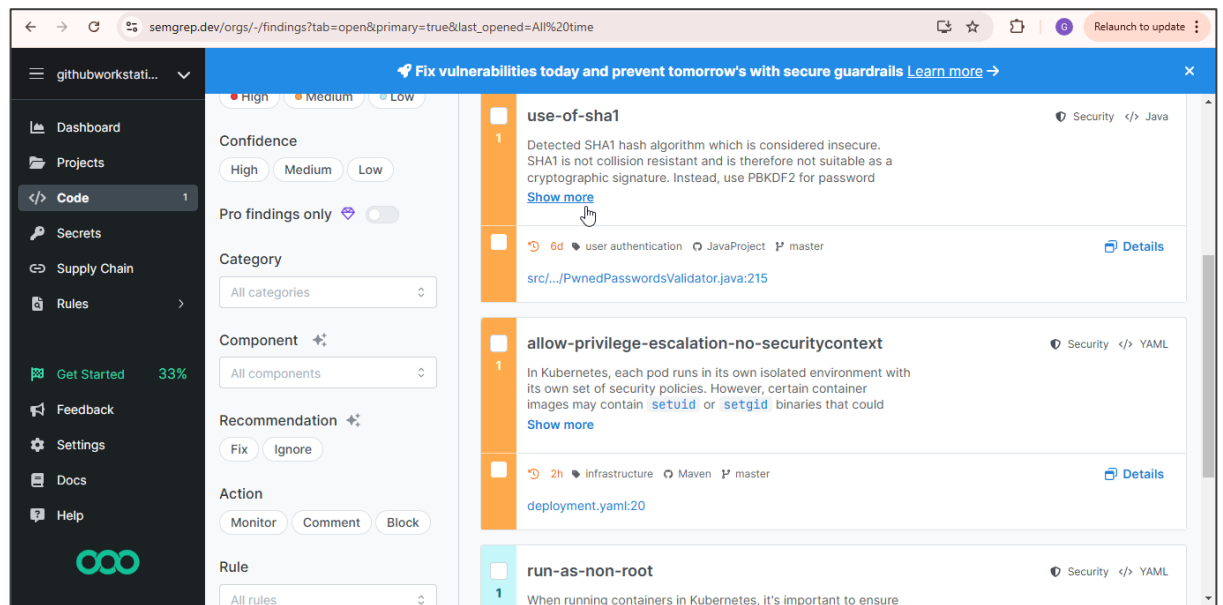
4.5 Click **Update maven.yml**, then select **semgrep/ci**, and choose the run configurations as shown below:



4.6 Verify the scan status and summary



4.7 Navigate to Semgrep website to view scan results



By following these steps, you have successfully executed a SAST scan on a static web application using GitHub workflows and integrated Semgrep for secure code analysis.